



**Swinburne University of Technology Hawthorn
Campus
Department of Computing Technologies**

COS30015 IT Security
Assignment 2 - Semester 2, 2024

Part B Incident Situational Report

Due Date: AEST 23:59 on 31/10/2024.

Having investigated all the artefacts provided by STARFLEET, they have requested a situation report update to understand the incident.

Compute the following template with your findings from your investigation.

STARFLEET SITREP		
Impacted STARFLEET Accounts	Student & Student ID	Student Name: Xuan Tuan Minh Nguyen Student ID: 103819212
	Class	Friday 8:30AM – 10:30AM
Affected Accounts: - Chris Pike - Admin	Tutor	Zeming Yao
Incident Timeline	Impacted STARFLEET Hosts	
09/09/2024 08:45:11 (PDT)	An email with a malicious file attachment was sent from an unknown server, mail.fakeemail.com, to chrispike@starfleet.com.	
09/09/2024 08:45:12 (PDT)	Chris Pike gets a phishing email from "Kaptian Kirk" - captain.kirk@starfleet.com- with a link to download a malicious document: NewStarfleetoffers.docx.	
09/09/2024 13:23:14 PM (UTC)	Chris Pike clicked the link to download the malicious document Lockheed_Martin_JobOpportunities.docx.	

10/09/2024 14:35:33 PM	Agent.exe is automatically triggered after Lockheed_Martin_JobOpportunities.docx is opened by Chris Pike. It was executed on Chris Pike's machine. It also shows the last run time of this file and the file ran once at this time, interacting with kernel32.dll. Host impacted: Chris Pike's machine - malicious file was executed on the machine. This machine is affected and will be used for further attack.
10/09/2024 10:24:01 AM	Chris Pike's account credential was used to connect to the Remote Access machine in the DMZ. (Event ID: 4624), which indicated in the log file successful remote login using Login Type 10 from 171.25.193.25 Host Affected: The Remote Access machine in the DMZ: This machine is infected and will further use for an attack.
10/09/2024 12:01:00 PM	Someone used credentials from Chris Pike's account to connect to Chris' computer using Microsoft's Remote Desktop Protocol (RDP), Event ID 4624: successful remote login, using Logon Type 10 from 192.168.200.10
10/09/2024 11:26:01 AM	After many failed attempts to login to the Admin account on the DC, the adversary successfully accessed the Admin using RDP from 192.168.100.20 Impacted host: Domain Controller. This is a critical security issue to happen in an unexpected manner; thus causing lots of security breaches.
IoCs Observed	TTPs Observed
File hashes: 0160375e19e606d06f672be6e43f70fa 70093d2a30031affd2929a5c446d07c1 a27a9324d282d920e495832933d486ee	Tactic: TA0001 – Initial Access - Technique: T1566.001 – Spearphishing Attachment • Description: The hacker sent a malicious file via email attachments as a safe file

d806e3e0c84b0b7208fb4ba9df5cd7b88f51abce5c0bbb3ee330560aaa139f243 IP Addresses and Domains: - 80.67.167.81 - 171.25.193.25 - 183.61.169.238 - 87.169.123.45 - phish@fakeemail.com - 1234567890abcdef@fakeemail.com - mail.fakeemail.com - client.fakeemail.com Log Event: - Event ID: 4625 File extension: .locked	Tactic: TA0002 – Execution - Technique: T1651 – Command and Scripting Interpreter • Sub-technique: T1059.003 – Windows Command Shell • Description: PowerShell Script has been executed in order to allow malware to execute. - Technique: User Execution (T1204) • Sub-technique: T1204.002 – Malicious File • Description: This malware tricked the victim (Chris Pike) to click and execute the malware. Tactic: TA0007 – Discovery • Technique: T1087 - Account Discovery • Description: Use the local user (Chris Pike) to discover the root account.
Remediation Advice	
- TA0001 – Initial Access: T1566.001 – Spearphishing Attachment • Description: The attacker tricked Chris Pike to open the Trojan file by making it look legitimate. • Remediation Advice: 1. Periodically Scanning Email: Create a spam filters and security solutions to scan malicious contents. In addition, perform total scanning of the company's email for a fix period. 2. Employees Training: Conduct workshops to train employees on how to differentiate phising emails and good email safety techniques. 3. Applying Machine Learning: Using Machine Learning to differentiate and raise cautions to employees if the email looks suspicious. - TTP: TA0002 – Execution: T1059.003 – Command and Scripting Interpreter • Description: The attacker performs Remote Command Execution (RCE) on Chris Pike machine and runs malicious code. • Remediation Advice: 1. Restrict Remote Command Execution (RCE) to who has permission: Only allows authorized personnel to conduct Remote Command Execution (RCE) will prevent the remote access attack. - TTP: TA0002 – Execution: T1204.002: User Execution	

- **Description:** Chris Pike unexpectedly allowed the backdoor attack by executed the malicious file
- **Remediation Advice:**
 1. **Employees Training:** Conduct workshops to train employees on how to differentiate a malicious file and how to use the anti-virus program effectively.
 2. **Anti-virus:** Use anti-virus programs to quarantine malwares and raise caution for user.
- **TTP: TA0007 – Discovery: T1087 – Account Discovery**
 - **Description:** The attacker use Chris Pike (local) account to query the admin accounts for finding exploitations.
 - **Remediation Advice:**
 1. Using Multi-factor Authentication (MFA) for all accounts, with admin account has the most restricted MFA.
 2. Actively collect and use Machine Learning to detect and mitigate the unusual activities
 3. Decouple systems that hold sensitive informations (e.g. DMZ) from the infrastructure to limit lateral movement.